

Seguretat Lògica

Una visió completa sobre la protecció dels sistemes i les dades. Estudi dels mecanismes de control d'accés, autenticació, autorització i polítiques de seguretat.



Sònia Rebordosa-2nSMX
Seguretat Informàtica

Índex de continguts

1	Introducció a la seguretat lògica	10	Sistemes biomètrics
2	Elements bàsics de control d'accés	11	Tipus de biometria
3	Objectes, subjectes i drets d'accés	12	Autenticació d'usuaris
4	Control d'accés discrecional (DAC)	13	Factors d'autenticació
5	Matrius i exemples	14	Autorització i criteris d'accés
6	Llistes de control d'accés (ACL)	15	Control d'accés i permisos
7	Política de contrasenyes	16	Permisos en UNIX
8	Creació de contrasenyes robustes	17	Registres i monitorització
9	Protecció de contrasenyes	18	Conclusions

Introducció a la seguretat lògica

La seguretat lògica consisteix en l'aplicació de barreres i procediments que resguarden l'accés a les dades i només permeten accedir a elles a les persones autoritzades per fer-ho.

Conceptes clau

- Control d'accés als recursos informàtics
- Identificació, autenticació i autorització
- Gestió d'usuaris eficient de permisos
- Complementa la seguretat física

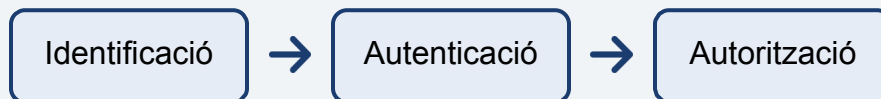


Importància

La seguretat lògica és una mesura fonamental de protecció contra accessos no autoritzats i forma part essencial de la cadena de seguretat informàtica.

Elements bàsics de control d'accés

En els sistemes informàtics, el control d'accés és una de les mesures més utilitzades per garantir la seguretat de la informació. Aquest mecanisme determina qui pot accedir als recursos i de quina manera.



Elements clau

- **Identificació:** Quan l'usuari es dona a conèixer al sistema
- **Autenticació:** Verificació de la identitat declarada
- **Autorització:** Determinació dels permisos de l'usuari
- **Single Login:** Autenticació única per accedir a múltiples recursos

Implementació

Per facilitar l'autenticació única (Single Login) s'utilitzen servidors d'autenticació centralitzats com LDAP (GNU/Linux) o Active Directory (Windows Server), que gestionen les credencials de tots els usuaris.



Objectes, subjectes i drets d'accés

Objecte: Recurs amb accés controlat (fitxers, directoris, registres, programes, pàgines de memòria, etc.).

Subjecte: Entitat capaç d'accedir als objectes (usuaris, processos, aplicacions).

Classes de subjectes

Propietari: creador d'un recurs

Grup: conjunt d'usuaris amb privilegis similars

Altres: usuaris que no pertanyen a cap grup

Drets d'accés

Lectura: visualitzar informació

Espectura: afegir, modificar o eliminar dades

Execució: executar programes

Esborrament: eliminar recursos

Creació: crear nous recursos



Exemple pràctic

Un servidor web té fitxers de configuració (objectes) als quals només poden accedir els administradors (subjectes) amb permisos de lectura i escriptura (drets). Els usuaris regulars (altres subjectes) només poden accedir als fitxers HTML públics (altres objectes) amb permisos de lectura.

Control d'accés discrecional (DAC)

El control d'accés discrecional (DAC) és una política de seguretat basada en la identitat del sol·licitant i en unes normes d'accés (autoritzacions) que indiquen el que poden o no poden fer els sol·licitants. El terme *discrecional* fa referència al fet que un subjecte pot tenir drets d'accés per donar a un altre subjecte drets d'accés per a un recurs concret.

Característiques principals

- Basat en la identitat del sol·licitant
- Permisos definits per l'administrador del sistema
- Possibilitat de delegació de permisos entre usuaris
- Implementació mitjançant matrius i llistes de control d'accés

Important

Les polítiques DAC permeten al propietari d'un recurs determinar qui hi té accés, cosa que dona flexibilitat als usuaris però pot complicar la gestió centralitzada de la seguretat.



Model DAC



L'usuari decideix qui té accés als seus recursos

Matriu de control d'accés: exemple pràctic

La matriu de control d'accés és una implementació del control d'accés discrecional (DAC). Representa els drets que tenen els subjectes (usuaris) sobre els objectes (recursos) del sistema.

Característiques

- Files = subjectes del sistema
- Columnes = objectes a protegir
- Cel·les = drets d'accés
- Es pot descompondre en columnes (ACL)
- Es pot descompondre en files (capacitats)
-

Una matriu es pot implementar de dues maneres diferents: per columnes (Llistes de Control d'Accés, ACL) o per files (capacitats associades als usuaris)

Subjectes/Objectes	/home/albert	/home/berta	/home/carme	/etc/passwd
Albert	Lectura, Escriptura, Execució	-	-	Lectura
Berta	-	Lectura, Escriptura, Execució	-	Lectura
Carme	Lectura, Execució	Lectura, Execució	Lectura, Escriptura, Execució	Lectura, Escriptura

Lectura (r): Visualització Escriptura (w): Modificació Execució (x): Execució/Accés

Exemple: L'usuari Carme té permisos administratius sobre tots els directoris personals

Llistes de control d'accés (ACL)

Les llistes de control d'accés (ACL) són un mecanisme que associa a cada objecte una llista de qui hi pot interactuar i com. Permeten gestionar amb detall els permisos d'accés a recursos com fitxers, directoris o recursos de xarxa.

Windows

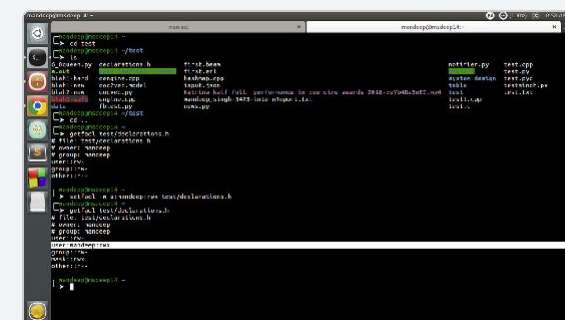
- Cada objecte té una ACL incorporada
- Conté entrades amb usuari/grup, operació i permís
- Permet permisos "permetre" o "denegar"
- El nucli comprova l'ACL quan s'accedeix a l'objecte
- Gestió centralitzada a través d'Active Directory

UNIX/Linux

- Sistema híbrid entre ACL i capacitats
- Cada objecte porta la seva llista de permisos
- Permisos bàsics rwx (lectura, escriptura, execució)
- Gestió amb comandes getfacl i setfacl
- Permet control més granular que el model clàssic

Avantatges de les ACL

Permeten una gestió de permisos més detallada i flexible que els sistemes tradicionals, facilitant l'administració de recursos en entorns multiusuari i garantint que només els usuaris autoritzats poden accedir als recursos necessaris.



Política de contrasenyes: introducció i origen

L'origen de les contrasenyes és molt anterior als sistemes informàtics. Es feia servir des de temps remots especialment en entorns militars per comprovar si algú pertanyia al bàndol amic o al bàndol contrari. Un sentinella demanava una "senya" i s'esperava una "contrasenya" com a resposta correcta.

Evolució: Des de la verificació d'identitat militar → Primers sistemes informàtics → Contrasenyes actuals

Importància actual

- Les contrasenyes són el mètode més estès per impedir accessos no autoritzats
- Econòmicament accessibles i, ben utilitzades, molt efectives
- Segons estudis, el mal ús de les contrasenyes és una de les deu amenaces més habituals
- Les polítiques institucionals estableixen normes i bones pràctiques

Què és una política de contrasenyes?

És un document que regula les normes de creació, protecció i renovació de les contrasenyes en una organització, per garantir la seguretat dels seus sistemes i dades.



Creació de contrasenyes robustes

Una contrasenya segura ha de ser difícil d'endevinar per un possible atacant. Utilitzar contrasenyes dèbils és una de les principals causes de vulnerabilitats en els sistemes.

Recomanacions

- Longitud mínima de 10 caràcters (recomanat 14)
- Combinar majúscules, minúscules, números i símbols
- No utilitzar dades personals (noms, dates, adreces)
- Evitar patrons de teclat (qwerty, 12345) o seqüències
- No reutilitzar contrasenyes entre diferents serveis

Tècnica mnemotècnica

Utilitza frases que recordis fàcilment per crear contrasenyes robustes.
Exemple: "Això és una manera de recordar una contrasenya" → Ae1MdR1c!



Contrasenyes	Seguretat
12345678	Molt dèbil
password	Molt dèbil
qwertyui	Dèbil
P@\$w0rd2024!	Mitjana
Lm4%Fi3pS@z9K	Robusta

Protecció i bones pràctiques de contrasenyes

Les contrasenyes han d'estar ben protegides, ja que si arriben a mans de possibles atacants aquests poden burlar la seguretat de tot el sistema. La política de contrasenyes ha d'establir com els usuaris han de protegir-les.

Normes bàsiques de protecció

Una contrasenya robusta perd tota utilitat si no es manté en secret. La majoria de bretxes de seguretat es produeixen per filtracions de credencials, no per atacs tècnics complexos.

Atenció! Canviar la contrasenya regularment (cada 6 mesos mínim) és una mesura eficaç per mantenir la seguretat dels accessos.



No escriure mai la contrasenya en un correu electrònic ni compartir-la per missatges.



No dir la contrasenya per telèfon a ningú, ni als superiors directes.



No parlar sobre les contrasenyes davant d'altres persones ni revelar-les a familiars.



No escriure en cap paper la contrasenya ni posar-la en adhesius visibles.



No posar pistes de la contrasenya per fer-la més fàcil de recordar.



Utilitzar un gestor de contrasenyes segur per emmagatzemar-les.

Sistemes biomètrics: introducció i funcionament

Els sistemes biomètrics verifiquen la identitat d'un usuari mitjançant l'anàlisi d'algun dels seus atributs físics o del seu comportament. Aquests sistemes ofereixen un nivell de seguretat superior quan les contrasenyes convencionals no són suficients.

Característiques principals

- Es basen en "alguna cosa que l'usuari és" o "alguna cosa que l'usuari fa"
- Requereixen un procés d'alta previ per registrar el patró de referència
- Poden classificar-se en sistemes estàtics (atributs físics) o dinàmics (comportament)
- Tot i ser molt robustos, no són infal·libles (falsos positius i negatius)

Funcionament bàsic

El sistema fa un escaneig d'un patró físic o de comportament de l'usuari i el compara amb una mostra model que té enregistrada. Si les dues mostres es consideren iguals, l'autenticació és correcta i es permet l'accés.



Tipus de sistemes biomètrics



Empremtes digitals

Sistema més comú basat en el relleu dels dits. Captura els punts característics (minúcies) per crear un patró únic. Ampliament utilitzat per la seva facilitat d'implementació, precisió i cost relativament baix. És el sistema biomètric més estès en dispositius mòbils i controls d'accés.



Reconeixement facial

Analitza les característiques úniques de la cara: distància entre ulls, estructura òssia, forma de la barbeta, etc. Utilitza càmeres estàndard o infraroges per capturar i analitzar els trets facials. Avantatge principal: no requereix contacte físic. Molt utilitzat en sistemes de vigilància i controls d'accés d'alta seguretat.



Escàner d'iris

Captura el patró de l'iris (la part acolorida de l'ull). L'iris conté informació única com anells, taques i colors. Extremadament precís, amb una taxa d'error molt baixa. Requereix una càmera especial amb il·luminació infraroja, però no necessita contacte directe amb l'usuari. Utilitzat en entorns d'alta seguretat.



Escàner de retina

Analitza el patró format pels vasos sanguinis de la retina. Utilitza llum infraroja de baixa intensitat que penetra a l'ull. És un dels sistemes més segurs, ja que el patró de la retina és gairebé impossible de falsificar. Principalment utilitzat en instal·lacions militars i governamentals d'alt nivell de seguretat.

Altres sistemes biomètrics inclouen: reconeixement de veu, geometria de la mà, reconeixement de signatura, patrons de pulsació de teclat i anàlisi de l'ADN. Cada tecnologia té diferents nivells de precisió, cost i acceptació per part dels usuaris.

Els sistemes biomètrics poden utilitzar-se individualment o combinats en sistemes d'autenticació multifactor per augmentar la seguretat.

Autenticació d'usuaris: identificació

La identificació és una manera d'assegurar-se que un subjecte (usuari o procés) és l'entitat que diu que és. Consisteix en obtenir una declaració d'identitat abans de procedir a l'autenticació i posterior autorització.

Aspectes clau de la identificació

- **Unicitat:** Cada individu ha de tenir un identificador únic al sistema (nom d'usuari, codi, etc.)
- **No descriptiva:** Cap part de la credencial no ha d'indicar la finalitat del compte (evitar noms com "admin" o "superusuari")
- **Expedició:** Elements proveïts per una autoritat reconeguda per demostrar la identitat (DNI, certificats, etc.)

Exemple pràctic d'estàndard d'identificació

A una organització, els identificadors d'usuari segueixen el format:
nom.cognom - sense caràcters especials (accents, enyes). Ex: maria.garcia, joan.puig



Recomanació

La identificació és només el primer pas. Sempre ha d'anar acompanyada d'una autenticació per verificar que l'usuari és realment qui diu ser.

Factors d'autenticació

L'autenticació és el procés de verificar que un usuari és qui diu ser. Es basa en diferents factors que poden combinar-se per augmentar la seguretat (autenticació multifactor).

Autenticació Multifactor (MFA)

- Combina dos o més factors d'autenticació
- Incrementa notablement la seguretat del sistema
- Mitiga el risc de compromís d'un sol factor
- Normalment implementada com a autenticació de dos factors (2FA)

Exemple pràctic: Per accedir al teu compte bancari necessites la contrasenya (coneixement) i un codi enviat al teu mòbil (possessió) o la teva empremta dactilar (inherència)

Procés típic d'autenticació de dos factors



Contrasenya

+



Codi SMS

=



Accés segur

Coneixement



Quelcom que l'usuari sap

- Contrasenyes
- PIN
- Preguntes secretes
- Patrons de desbloqueig

Possessió



Quelcom que l'usuari té

- Targetes intel·ligents
- Tokens de seguretat
- Dispositiu mòbil
- Clau física (USB)

Inherència



Quelcom que l'usuari és

- Empremtes dactilars
- Reconeixement facial
- Escaneig d'iris/retina
- Reconeixement de veu

Factors addicionals: ubicació (on està l'usuari) i comportament (com actua l'usuari)

Autorització i criteris d'accés

L'autorització és el procés que determina què pot fer un usuari un cop ha estat identificat i autenticat dins del sistema. Facilita a l'administrador la tasca d'autoritzar l'accés als recursos mitjançant diferents criteris de control.

Criteris d'accés

- **Rols:** Permisos basats en la funció o tasca específica (auditor, administrador, editor...)
- **Grups:** Permet donar permisos similars a conjunts d'usuaris (professorat, alumnat...)
- **Localització:** Física (només accés des d'un lloc concret) o lògica (per adreça IP)
- **Hora d'accés:** Restricció per franja horària (p. ex. horari laboral)
- **Tipus de transacció:** Restriccions segons l'operació (consulta, modificació...)

Exemple pràctic

En un institut, el grup de professorat té accés als directoris i fitxers d'assignatures en mode lectura/escriptura, mentre l'alumnat només en mode lectura, i només es pot accedir al servidor durant l'horari lectiu.



Control d'accés als recursos i permisos

Per garantir la seguretat d'un sistema informàtic, l'administrador pot decidir i configurar l'entorn per controlar qui està autoritzat a utilitzar cada recurs i qui no.

Diferència entre permisos i drets

- Permisos: Controlen l'accés als recursos (fitxers, directoris, registres)
- Drets d'usuari: Determinen quines tasques pot dur a terme l'usuari al sistema
- Els permisos poden ser assignats a usuaris individuals o grups
- L'administrador gestiona permisos mitjançant ACL o altres mecanismes

Principi del mínim privilegi

Els usuaris només haurien de tenir els permisos mínims necessaris per realitzar les seves tasques. Aquest principi redueix els riscos de seguretat i evita possibles errors amb conseqüències greus.



Permisos	Drets
Lectura	Reiniciar sistema
Escriptura	Canviar data/hora
Execució	Gestio d'usuaris

Permisos en sistemes UNIX

Els sistemes UNIX utilitzen un model de permisos basat en tres categories d'usuaris (propietari, grup i altres) i tres tipus de permisos (lectura, escriptura i execució).

Comandes bàsiques

- **chmod:** canvia els permisos d'arxius i directoris
- **chown:** canvia el propietari d'un arxiu o directori
- **chgrp:** canvia el grup d'un arxiu o directori

Exemple: `chmod u=rwx,g=rx,o=r arxiu.txt` assigna permisos de lectura, escriptura i execució al propietari, lectura i execució al grup, i només lectura als altres usuaris.

```
$ ls -l
-rw-rw-r-- 1 joan profes 31744 Feb 21 seguretat.doc
$ chmod u+x seguretat.doc
$ ls -l
-rwxrw-r-- 1 joan profes 31744 Feb 21 seguretat.doc
Afegeix permís d'execució al propietari
```

Permís	Símbol	Propietari	Grup	Altres
Lectura	r	4	4	4
Espectura	w	2	2	2
Execució	x	1	1	1

Notació numèrica: `rwxr-xr--` = 754
Tipus d'objecte: (-) arxiu, (d) directori, (l) enllaç simbòlic
Posicions: `rwx | rwx | rwx` = (propietari | grup | altres)

```
$ chown maria:estudiants projecte.pdf
Canvia el propietari a "maria" i el grup a "estudiants"
```

```
$ chgrp professors document.txt
Canvia el grup a "professors" mantenint el propietari
```

Registres d'usuaris, incidències i monitorització

Els registres (logs) de seguretat són essencials per a la detecció d'incidents, auditoria i compliment normatiu. Revisar registres que no s'analitzen és tan inefectiu com no guardar-los, per això és important definir polítiques clares de gestió i anàlisi.

Tipus de registres més rellevants

- Registres dels sistemes operatius: intents d'accés, bloqueigs d'usuaris, utilització d'eines d'administració
- Registres de programari de seguretat: antivirus, tallafocs, sistemes de detecció d'intrusions
- Registres de les aplicacions crítiques amb informació sensible
- Registres d'accés remot i activitat als servidors

Bones pràctiques

Centralitzar els registres, gestionar volums adequats, sincronitzar els rellotges dels sistemes, protegir la integritat amb mètodes criptogràfics i crear còpies en mitjans protegits per evitar manipulacions.



Informació que cal registrar:

Intents d'accés (reeixits i fallits)
Data i hora dels accessos
Identitat dels usuaris
Dispositius utilitzats
Canvis en la configuració